



Ethical Hacking

SANJAY POONYTH, CISM

What is it all about?

- ▶ Assets (data) – Vulnerabilities – Threats

- ▶ C I A – Holy Trinity of Security

- ▶ Are you breaking the law?

Computer Misuse and Cybercrime Act 2003 - DPA/GDPR 2017

HIPAA (Health Insurance -1996), Homeland Security Act (2002) – 4 new acts in 2015 (Breach Notification & Cybersecurity)

- ▶ Do you have written permission of the owner?

Country	GCI Score	Legal	Technical	Organizational	Capacity Building	Cooperation
Mauritius	0.83	0.85	0.96	0.74	0.91	0.7
Rwanda	0.6	0.6	0.71	0.79	0.66	0.28
Kenya	0.57	0.75	0.73	0.36	0.41	0.6

Source : Table 6.1.1: Top three ranked countries in Africa

				Organizational	Capacity Building	Cooperation
Singapore	0.92	0.95	0.96	0.88	0.97	0.87
United States	0.91	1	0.96	0.92	1	0.73
Malaysia	0.89	0.87	0.96	0.77	1	0.87
Oman	0.87	0.98	0.82	0.85	0.95	0.75
Estonia	0.84	0.99	0.82	0.85	0.94	0.64
Mauritius	0.82	0.85	0.96	0.74	0.91	0.70
Australia	0.82	0.94	0.96	0.86	0.94	0.44
Georgia	0.81	0.91	0.77	0.82	0.90	0.70
France	0.81	0.94	0.96	0.60	1	0.61
Canada	0.81	0.94	0.93	0.71	0.82	0.70

Source : Table 5.1: Top ten most committed countries, GCI (normalized score)

Some definitions!

- ▶ Defensive or Offensive Posture
- ▶ White Hats vs Black Hats (Gray Hats?)
- ▶ Red Teams vs Blue Teams (Purple Teams?)
- ▶ White box vs Black box (Gray Box?)
- ▶ Hacktivists, Suicide Hackers, State sponsored Hackers!
- ▶ Security Audit vs Vulnerability Scanning vs Penetration Testing

Ethical Hacking - General Steps

- ▶ Reconnaissance (Footprinting)
- ▶ Scanning & Enumeration
- ▶ Gaining Access
- ▶ Maintaining/Escalating Access
- ▶ Covering Tracks



Written
Authorisation
!!!

Reconnaissance - Scanning - Gaining Access - Maintaining/Escalating Access - Covering Tracks

- ▶ Passive vs Active (website or people Search, try to go inside the company)
- ▶ Where is your data (Website, facebook, Linkedin, WhatsApps, Twitter,....)
- ▶ Dumpster diving (Shredders, Bins,...)
- ▶ Social Engineering
- ▶ Professional Tools for data collection
- ▶ Ask for it!

Reconnaissance - **Scanning** - Gaining Access - Maintaining/Escalating Access - Covering Tracks

- ▶ OSI Model – Know your layers
- ▶ TCP handshake (Sync, Sync/Ack,...)
- ▶ Ping Sweep, Network/Asset Mapping, Packet Manipulation
- ▶ Open Ports, Vulnerability Scanning, Scanning behind the firewall
- ▶ Is scanning legal or illegal?

Reconnaissance - Scanning - **Gaining Access** - Maintaining/Escalating Access - Covering Tracks

- ▶ Deploy attacks against uncovered vulnerabilities
 - ▶ DOS & DDOS
 - ▶ Phishing attacks
 - ▶ Password cracks
 - ▶ SQL injection
 - ▶ Buffer overflows
 - ▶ Wireless Attacks
 - ▶ Mobile Attacks
 - ▶ Malware attacks
 - ▶ + hundreds more.....targeted at CIA or each layer of the OSI model

▶ Hacking the Human OS !

Reconnaissance - Scanning - Gaining Access - **Maintaining/Escalating Access** - Covering Tracks

- ▶ Ensure a way back into compromised machine or system
- ▶ Trojans, Rootkits, Back doors, Zombies,
- ▶ Placing a sniffer for specific monitoring.
- ▶ Escalating Privileges (gaining Administrative Access)
- ▶ Have you been Hacked?

<https://www.shodan.io/>, <https://haveibeenpwned.com/>,

Reconnaissance - Scanning - Gaining Access - Maintaining/Escalating Access - **Covering Tracks**

- ▶ Conceal Success and Avoid Detection
- ▶ Delete or Modify Logs
- ▶ Hide Files
- ▶ Do Ethical Hackers fix vulnerabilities?
- ▶ Do penetration Testers exploit vulnerabilities (a DDOS attack that will bring down the company's network)?

Illegal Acts!

- ▶ Impersonation
- ▶ Fake Profile on Facebook
- ▶ Scanning of public IP's
- ▶ Truth in Caller ID